Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 5

What you get . . . 5

What this delivers . . . 5

The deployment model . . . 6

Outcome . . . 6

1. Solution Overview — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 6

What phishing-resistant, passwordless authentication is . . . 6

How it works . . . 6

FIDO2 keys vs. Windows Hello for Business vs. certificate-based auth (CAC/PIV) . . . 7

Commercial vs GCC High — what's different . . . 7

What you can control . . . 8

Benefits . . . 8

Limitations (be honest with buyers) . . . 9

The standard deployment model . . . 9

2. Requirements Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 9

2.0 Sovereign endpoints (GCC High / DoD) . . . 9

2.1 Licensing (US Gov SKUs) . . . 10

2.2 Admin roles . . . 10

2.3 Break-glass accounts . . . 10

2.4 Authentication methods policy available . . . 11

2.5 FIDO2 security keys (hardware + support) . . . 11

2.6 Windows Hello for Business readiness . . . 11

2.7 Certificate-based authentication (CAC / PIV) — often primary for DoD/federal . . . 11

2.8 Conditional Access readiness . . . 11

2.9 Pilot and rollout groups . . . 12

2.10 Onboarding bootstrap method (verify for GCC High) . . . 12

Checklist . . . 12

Global Requirements — Entra ID Solutions (category-level) 12

G1. Microsoft Entra ID tenant . . . 13

G2. Entra ID licensing (P1 / P2) . . . 13

G3. Administrative roles . . . 13

G4. Break-glass (emergency-access) accounts . . . 13

G5. Authentication methods policy access . . . 13

G6. Conditional Access baseline . . . 13
G7. Network access to Microsoft cloud endpoints . . . 13
GCC High Parity Notes — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys 14
1. Sovereign endpoints (confirmed) . . . 14
2. Phishing-resistant methods — Generally Available in US Gov (confirmed) . . . 15
3. Certificate-based authentication (CBA) — the DoD / federal path (confirmed GA; details verify) . 16
4. Known differences and limitations vs Commercial (confirmed) . . . 16
5. Verify for GCC High (unconfirmed sovereign parity — do not assume Commercial parity) . . . 17
6. Sources . . . 18
3. Implementation Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 18
Step 1 — Create the groups . . . 19
Step 2 — Enable FIDO2 security keys . . . 19
Step 3 — Enable Windows Hello for Business . . . 19
Step 4 — Enable certificate-based authentication (CAC / PIV) — primary for DoD/federal . . . 19
Step 5 — Decide the onboarding bootstrap (verify TAP for GCC High) . . . 20
Step 6 — Register the pilot . . . 20
Step 7 — Create the phishing-resistant authentication strength . . . 20
Step 8 — Enforce on the pilot via Conditional Access . . . 20
Step 9 — Validate the pilot . . . 21
Step 10 — Expand to all staff . . . 21
5. Testing Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 21
Test 0 — Sovereign cloud confirmed . . . 21
Test 1 — Methods enabled . . . 22
Test 2 — User can register a phishing-resistant credential . . . 22
Test 3 — Passwordless sign-in works . . . 22
Test 4 — Registration coverage . . . 22
Test 5 — Authentication strength exists . . . 22
Test 6 — Conditional Access enforces the strength . . . 22
Test 7 — Break-glass unaffected . . . 22
Test 8 — Certificate-based auth counts as MFA (if used) . . . 22
Pass/fail gate . . . 23
6. Troubleshooting Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 23
A. Wrong cloud / sovereign-endpoint problems (GCC High-specific — check first) . . . 23
B. Users locked out after enforcement . . . 24

C. FIDO2 key won't register . . . 24
D. Onboarding bootstrap missing (TAP) . . . 24
E. Windows Hello for Business not provisioning . . . 24
F. Conditional Access not requiring the strength . . . 24
G. Certificate-based authentication (CAC/PIV) failing . . . 25
H. Diagnostics quick reference (Microsoft Graph PowerShell — US Gov) . . . 25
I. When to escalate . . . 25
7. Best Practices — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 26
Sovereign-cloud discipline . . . 26
Choose the right method for government . . . 26
Registration always leads enforcement . . . 26
Conditional Access safety . . . 26
Key/credential lifecycle . . . 27
Naming, reuse, and auditability . . . 27
Compliance framing . . . 27
8. Deliverables Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High) 27
Documentation . . . 27
PowerShell scripts (US Gov Graph — `-Environment USGov`) . . . 28
What the buyer receives . . . 28
Outcome . . . 29
Appendix A — PowerShell Scripts 30

Executive Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

White-label · Entra ID Solutions · US Sovereign Cloud (GCC High / DoD)

Passwords get phished, and even push-based MFA gets bombed until a tired user taps "Approve." For US Government tenants this is not just a security preference — **Executive Order 14028** and **OMB M-22-09** direct federal agencies toward **phishing-resistant MFA**, and **CMMC / NIST SP 800-171** push the same requirement onto the defense-industrial base. This solution stands up **passwordless and phishing-resistant MFA in Microsoft Entra ID** — FIDO2 hardware security keys, Windows Hello for Business, and **certificate-based authentication with CAC/PIV smart cards** — enabled as authentication methods, registered by users, and then **enforced** through a Conditional Access authentication strength so weak, phishable methods can no longer get in.

This is the **Government (GCC High) edition**: it deploys on the **US sovereign cloud** using the `*.us` admin portals (`entra.microsoft.us`, `portal.azure.us`, `portal.office365.us`) and **US Gov Graph** (`-Environment USGov`), and it calls out where sovereign capabilities differ from Commercial so the tenant is configured correctly — not with Commercial steps that silently authenticate against the wrong cloud.

This is a complete, **deploy-it-today** package for a competent administrator with no prior passwordless experience: every screen, every object name, every gate.

What you get

- A plain-language **Solution Overview** of the Entra authentication-methods model, FIDO2 vs. Windows Hello vs. certificate-based (CAC/PIV), and Conditional Access authentication strengths — with an explicit **Commercial vs GCC High — what's different** section.
- A **Requirements Guide** with verify / implement-if-missing for every prerequisite, on the `*.us` plane.
- An **Implementation Guide** of precise, click-by-click **sovereign** steps in the required order, with GCC-High caveats inline.
- Five **PowerShell scripts** (US Gov Graph) for auth-methods readiness discovery, per-user passwordless registration validation, a tenant credential-method coverage report, safe remediation of weak-method users, and a rollout target-group builder.
- **Testing**, **Troubleshooting**, and a cited **GCC High Parity Notes** reference with explicit pass/fail gates.

What this delivers

A **phishing-resistant credential program** on the sovereign cloud — FIDO2 keys, Windows Hello for Business, and CAC/PIV smart cards registered across a pilot then the staff, a named **authentication strength** (`Phishing-Resistant`) created once, and a Conditional Access policy that **requires** that strength so legacy password+SMS/push sign-ins are blocked. The core methods (FIDO2, Windows Hello, certificate-based auth) and Conditional Access are all **Generally Available in US Gov**; the package flags Authenticator-passkey, TAP, and registration-campaign features as "verify for GCC High" and gives GA fallbacks.

The deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — with a pilot gate before any enforcement reaches all staff.

Outcome

Users signing in passwordless with phishing-resistant credentials, weak methods blocked by a Conditional Access authentication strength, and break-glass access preserved — configured on the US sovereign (`*.us`) cloud and proven on a pilot before you scale, deployable by a single administrator.

1. Solution Overview — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

> *This is the **Government (GCC High)** edition. It deploys the same phishing-resistant, passwordless authentication model as the Commercial edition, but on the **US sovereign cloud**: the admin portals, sign-in endpoints, and Microsoft Graph endpoints are the `*.us` sovereign URLs, and a few adjacent capabilities lag or differ from Commercial. Configure a GCC High tenant with these steps — not with Commercial steps that silently authenticate against the wrong cloud.*

What phishing-resistant, passwordless authentication is

Passwordless means a user signs in **without typing a password** — proving identity with a hardware-backed credential bound to the device or a security key. Phishing-resistant means the credential **cannot be replayed against an attacker's fake site**: it is cryptographically bound to the real sign-in origin, so a phished code or an approved push can't be reused. In Microsoft Entra ID, the phishing-resistant, passwordless methods are **FIDO2 security keys**, **Windows Hello for Business**, and **certificate-based authentication** (smart cards — CAC / PIV). This solution turns those on, gets users registered, and then enforces them.

For a US Government tenant this is not optional polish. Executive Order 14028 and OMB M-22-09 direct federal agencies toward **phishing-resistant MFA**, and CMMC / NIST SP 800-171 push the same requirement onto the defense-industrial base. FIDO2 keys and CAC/PIV smart cards are the methods that satisfy it.

How it works

1. Entra ID's **Authentication methods** policy (at `https://entra.microsoft.us`) enables each method (FIDO2, Windows Hello for Business, certificate-based auth) and scopes *who* can register it.

2. Users **register** a credential — tapping/plugging a FIDO2 key, enrolling Windows Hello, or being issued a smart-card certificate — at the sovereign security-info portal (`https://aka.ms/mysecurityinfo`, which resolves to the US Gov My Sign-Ins) or during supervised enrollment.

3. A Conditional Access **authentication strength** defines the set of acceptable methods (the built-in *Phishing-resistant MFA* strength, or a custom one).

4. A Conditional Access **policy** requires that strength for the targeted users, so a password+SMS or password+push sign-in is **blocked** — only a phishing-resistant credential satisfies the grant.

5. Coverage and registration are reported from Entra (registration details) so you can see who is ready before you enforce. In this edition the reporting scripts query **US Gov Graph** (`-Environment USGov`).

FIDO2 keys vs. Windows Hello for Business vs. certificate-based auth (CAC/PIV)

• **FIDO2 security keys** — a portable hardware key (USB/NFC) the user taps. Best for shared workstations, kiosks, frontline, and admins who roam between machines. Phishing-resistant by design. Prefer FIPS 140-validated keys for government use.

• **Windows Hello for Business** — a credential bound to a specific Windows PC, unlocked by PIN or biometric. Best for assigned, single-user devices.

• **Certificate-based authentication (CAC / PIV)** — X.509 certificates on a smart card. **This is usually the primary method for DoD (CAC) and federal-civilian (PIV) tenants**, because the smart-card credential already exists on the badge. Entra CBA authenticates the certificate **directly to Entra ID** (not through AD FS), which the U.S. GSA describes as a phishing-resistant, Conditional-Access-verifiable sign-in.

Commercial vs GCC High — what's different

The authentication model is identical; the **cloud plane it runs on is not**. In GCC High:

• **You sign in and administer at sovereign `*.us` portals**, not the Commercial `*.com` portals. The Commercial portals will not recognize a GCC High account. (See the Requirements Guide for the full endpoint table.)

• Microsoft Entra admin center: `https://entra.microsoft.us` (Commercial: `entra.microsoft.com`).

• Azure portal: `https://portal.azure.us` (Commercial: `portal.azure.com`).

• Microsoft 365 admin center: `https://portal.office365.us` (Commercial: `admin.microsoft.com`).

• Sign-in / authentication: `https://login.microsoftonline.us` (Commercial: `login.microsoftonline.com`).

• Microsoft Graph: `https://graph.microsoft.us` for GCC High, `https://dod-graph.microsoft.us` for DoD (Commercial: `graph.microsoft.com`). Source: Microsoft Learn, *Microsoft Graph national cloud deployments*.

• **Scripts must target US Gov Graph.** Every `Connect-MgGraph` call in this solution uses `-Environment USGov` (or `USGovDoD` for DoD); without it the SDK authenticates against the Commercial endpoint and fails against a GCC High tenant. All five scripts in this package default to `-Environment USGov`.

• **The core methods are GA in US Gov.** Microsoft's *Entra feature availability in Azure for US Government* lists **Passwordless (Windows Hello for Business, Microsoft Authenticator, FIDO2 security key integrations)**, **Certificate-based authentication**, and **Conditional Access** all as

available (■). The whole program in this solution is built on these GA methods. Source: Microsoft Learn, *Microsoft Entra feature availability in Azure for US Government*.

• **Certificate-based auth is the DoD/federal centerpiece.** Because CAC/PIV cards already exist, CBA is often the primary phishing-resistant method — direct-to-Entra, no AD FS. See `gcc-high-parity-notes.md` §3 for binding details, and **verify the current CBA configuration for GCC High/DoD** at deployment time.

• **Some adjacent capabilities lag, are partial, or differ** — call these out and verify against the current sovereign docs before relying on them:

• **Passkeys in Microsoft Authenticator, cross-device (QR) passkey sign-in, and synced passkeys** (Apple/Google) are **not confirmed** for GCC High — Authenticator-dependent features often lag in the sovereign clouds. **Verify for GCC High**; default to a **hardware FIDO2 key** or **CBA smart card**.

• **Temporary Access Pass (TAP)** as the passwordless bootstrap credential is **not called out** in the US Gov feature table — **verify for GCC High** before designing onboarding around it; have an in-person enrollment fallback.

• **Registration campaign** (nudge to add a method at sign-in) — confirm the sub-feature is present in your sovereign tenant; if absent, drive registration by communication + supervised enrollment.

• **My Staff** (delegated helpdesk portal for frontline registration) is listed **not available** (■) for US Gov.

• **Microsoft Entra threat intelligence** (one ID Protection detection) is **not available** (■); most other risk detections *are* available, so risk-based enforcement is still possible.

• **Graph Explorer** (the browser tool) is **not supported** for `graph.microsoft.us`/DoD — use PowerShell (`-Environment USGov`), which is exactly what this package's scripts do.

*Where this document says **"verify for GCC High,"** treat the capability as unconfirmed for the sovereign cloud: check the current Microsoft US Gov documentation (or the Microsoft 365 US Government service descriptions) before you depend on it. Never assume Commercial parity for a preview, Microsoft-Authenticator, or cross-cloud feature. Full detail is in `gcc-high-parity-notes.md`.*

What you can control

• Which methods are enabled and **who may register** each (per-group scoping), on the sovereign Authentication methods policy.

• Optional **AAGUID restriction** — allow-list specific certified (ideally FIPS-validated) FIDO2 key models.

• The **authentication strength** required (built-in Phishing-resistant MFA, or a custom strength combining FIDO2 / Windows Hello / CBA).

• The Conditional Access **scope** (pilot group first, then all staff), with break-glass exclusions.

Benefits

• **Phishing-resistant** — credentials can't be replayed against fake sites; push-bombing stops working.

• **Passwordless** — no password to phish, spray, or reuse; better user experience.

• **Mandate-ready** — meets EO 14028 / OMB M-22-09 phishing-resistant-MFA direction and supports CMMC / NIST 800-171 authentication objectives common to GCC High tenants.

• **Enforceable** — Conditional Access authentication strengths block weak methods, not just recommend strong ones.

• **Measurable** — registration and method-coverage reporting (US Gov Graph) before and after enforcement.

• **Sovereign-correct** — configured on the `*.us` plane so a government tenant is secured in-cloud, not against Commercial endpoints.

Limitations (be honest with buyers)

• FIDO2 keys and certificate-based auth need **hardware** (keys, or a PKI/smart-card stack) — a procurement and distribution step. In DoD/federal the smart cards usually already exist.

• Enforcing a phishing-resistant strength **before** users are registered will lock them out — registration must lead enforcement (hence the pilot gate).

• Certificate-based authentication requires a configured certificate authority, trust chain, and username binding in Entra; **verify the current CBA binding requirements for GCC High/DoD**.

• Some legacy / line-of-business apps and protocols don't honor modern auth; inventory them before tenant-wide enforcement.

• GCC High parity gaps apply to Authenticator-based passkeys, TAP, registration campaign, and My Staff (see *Commercial vs GCC High* above and `gcc-high-parity-notes.md`) — verify before relying on them.

The standard deployment model

> ***Enable methods → register users (supervised / campaign if available) → create the phishing-resistant authentication strength → require it via Conditional Access on the pilot → validate → expand to all staff.*** *Registration always leads enforcement so no one is locked out. Pattern:* ***Assess → Configure → Pilot → Validate → Expand.***

2. Requirements Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-entra-id-solutions.md`. This edition targets the **US sovereign cloud** — use the `*.us` portals and US Gov Graph throughout.

2.0 Sovereign endpoints (GCC High / DoD)

Description: Administer on the `*.us` plane; the Commercial `*.com` portals reject GCC High accounts. **Why:** Signing in or scripting against the wrong cloud fails or silently targets the wrong tenant. **Verify:** You can sign in at `https://entra.microsoft.us`; `FIDO2G-Discovery.ps1` connects with

`-Environment USGov`.

Purpose	GCC High	DoD	Commercial
Entra admin center	`https://entra.microsoft.us`	`https://entra.microsoft.us`	`entra.microsoft.com`
Azure portal	`https://portal.azure.us`	`https://portal.azure.us`	`portal.azure.com`
Microsoft 365 admin center	`https://portal.office365.us`	`https://portal.office365.us`	`admin.microsoft.com`
Sign-in	`https://login.microsoftonline.us`	`https://login.microsoftonline.us`	`login.microsoftonline.com`
Microsoft Graph	`https://graph.microsoft.us`	`https://dod-graph.microsoft.us`	`graph.microsoft.com`
Graph PowerShell `-Environment`	`USGov`	`USGovDoD`	`Global`

Implement: Bookmark the sovereign portals; always pass `-Environment USGov` (or `USGovDoD`) in scripts. Source: Microsoft Learn, *Microsoft Graph national cloud deployments*.

2.1 Licensing (US Gov SKUs)

Description: Entra ID P1 (Conditional Access + authentication strengths); P2 only if you add risk-based enforcement. In the sovereign clouds these ship inside the **Government** bundles. **Why:** Authentication strengths are delivered through Conditional Access, which requires Entra ID P1 (`AAD_PREMIUM`); risk-based Conditional Access needs P2 (`AAD_PREMIUM_P2`). **Verify:** M365 admin center (`https://portal.office365.us`) → **Billing** → **Licenses**; look for the Entra P1/P2 service plan. **Implement:** Assign **Microsoft 365 G3** (carries `AAD_PREMIUM` / P1) or **G5** (carries `AAD_PREMIUM_P2` / P2), or **EMS E3/E5 for Government**, or standalone Entra ID P1/P2 for Government. FIDO2, Windows Hello for Business, and CBA method enablement do not themselves require a premium SKU, but the **Conditional Access enforcement** does.

2.2 Admin roles

Description: Authentication Policy Administrator + Conditional Access Administrator for the operator. **Why:** You will edit the Authentication methods policy and create Conditional Access policies. **Verify:** Entra (`entra.microsoft.us`) → **Roles and administrators**. **Implement:** Assign both roles; reserve Global Administrator for tenant-wide changes. (See global G3.)

2.3 Break-glass accounts

Description: Two cloud-only emergency-access accounts excluded from Conditional Access. **Why:** An authentication-strength policy can lock out all admins; break-glass preserves access. Critical on GCC High, where support-assisted recovery is slower. **Verify:** Entra → **Users**; two

`*.onmicrosoft.us`/`*.onmicrosoft.com` cloud-only accounts excluded from every CA policy. **Implement:** Create them, store credentials offline, exclude from all CA policies, monitor sign-ins. (See global G4.)

2.4 Authentication methods policy available

Description: The converged **Authentication methods** policy is in use (not the legacy MFA settings). **Why:** FIDO2, Windows Hello for Business, and certificate-based auth are enabled here. **Verify:** Entra → **Protection** → **Authentication methods** → **Policies** opens; run `FIDO2G-Discovery.ps1`. **Implement:** Migrate from legacy MFA/SSPR method settings to the Authentication methods policy. (See global G5.)

2.5 FIDO2 security keys (hardware + support)

Description: FIDO2-certified security keys procured for in-scope users; modern browsers/OS for WebAuthn. Prefer **FIPS 140-validated** keys for government use. **Why:** FIDO2 is the portable, phishing-resistant credential for roaming users and admins. **Verify:** Keys on hand; user devices on a supported OS/browser; run `FIDO2G-Discovery.ps1` (FIDO2 method state). **Implement:** Procure FIPS-validated FIDO2 keys; optionally restrict to specific key models by **AAGUID** in the FIDO2 method settings. AAGUID restriction is part of the GA FIDO2 configuration — **verify the exact sovereign-portal UI**.

2.6 Windows Hello for Business readiness

Description: Windows 10/11 devices able to provision Windows Hello (Entra-joined or hybrid). **Why:** Windows Hello is the device-bound passwordless credential for assigned PCs. **Verify:** Devices are Entra-joined/registered; run `FIDO2G-Discovery.ps1`. **Implement:** Enable Windows Hello for Business (Intune policy at `https://endpoint.microsoft.us`, or the Authentication methods policy); ensure a TPM is present.

2.7 Certificate-based authentication (CAC / PIV) — often primary for DoD/federal

Description: A configured certificate authority and trust chain in Entra, username binding set, and issued CAC/PIV smart cards. **Why:** For DoD (CAC) and federal-civilian (PIV) tenants this is usually the primary phishing-resistant method — the smart card already exists. **Verify:** Entra → **Protection** → **Show more** → **Certificate-based authentication** shows CAs configured; a test smart-card sign-in succeeds. Listed ■ **Available** for US Gov (feature-availability table). **Implement:** Upload the issuing/root CA chain to the Entra **certificate authorities** store; configure **username binding** (e.g. `PrincipalName` / `RFC822Name`, or `certificateUserIds`); set **authentication-binding** so a hardware-smart-card certificate policy counts as MFA. **Verify the current CBA binding requirements for GCC High/DoD** (see `gcc-high-parity-notes.md` §3). Sources: Microsoft Learn *feature availability*; U.S. GSA IDManagement *CBA on Entra ID*.

2.8 Conditional Access readiness

Description: Conditional Access available; an app/service inventory for tenant-wide enforcement. **Why:** Enforcement uses an authentication-strength grant; legacy apps/protocols may not honor it. **Verify:** Entra

→ **Protection** → **Conditional Access** → **Policies**; run `FIDO2G-Report.ps1` for current method coverage. Conditional Access is ■ **Available** in US Gov. **Implement:** Plan policy scope; start in **Report-only**; identify exclusions for legacy protocols. (See global G6.)

2.9 Pilot and rollout groups

Description: Entra security groups for the pilot and the broad/all-staff rollout. **Why:** Method scoping, registration, and CA enforcement target groups, piloted first. **Verify:** Entra → **Groups**; pilot + rollout groups exist (or build with `FIDO2G-Set-ScopeTargeting.ps1`). **Implement:** Create `Phishing-Resistant – Pilot – Users` and `Phishing-Resistant – All Staff – Users`.

2.10 Onboarding bootstrap method (verify for GCC High)

Description: A way to register a first passwordless method before one exists — Temporary Access Pass (TAP), or supervised in-person enrollment. **Why:** A brand-new user with no credential needs a bootstrap to register a key or enroll Windows Hello. **Verify:** Entra → **Protection** → **Authentication methods** → **Policies** → **Temporary Access Pass** — confirm it is present and enabled in your **sovereign** tenant. TAP is **not called out** in the US Gov feature table — **verify for GCC High**. **Implement:** If TAP is available, enable it scoped to the pilot; if not, use **in-person supervised enrollment** (or CAC/PIV issuance) as the bootstrap. Do not assume TAP parity.

Checklist

- Sovereign `*.us` portals reachable; scripts use `-Environment USGov`
- Entra ID P1 (Government) licensing assigned (P2 if risk-based)
- Authentication Policy + Conditional Access Administrator roles
- Two break-glass accounts excluded from CA
- Authentication methods policy in use — `FIDO2G-Discovery.ps1`
- FIDO2 (FIPS-validated) keys procured; OS/browser supported
- Windows Hello for Business readiness confirmed
- Certificate-based auth (CAC/PIV) CA + binding configured (verify for GCC High)
- Conditional Access ready; legacy-app exclusions identified
- Pilot + rollout Entra groups created
- Onboarding bootstrap decided (TAP verified, or supervised enrollment)

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to **every** solution in the **Entra ID Solutions** category. They are published once at the category level so individual listings stay small. Confirm these before deploying *any* Entra ID identity solution. Each entry: **Description · Why · Verify · Implement-if-missing.**

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. **Why:** It is the identity backbone that issues credentials, evaluates Conditional Access, and stores authentication methods. **Verify:** Sign in to `https://entra.microsoft.com` as an administrator; the tenant Overview loads. **Implement:** Create a Microsoft 365 / Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1 / P2)

Description: Entra ID P1 for Conditional Access; P2 for risk-based policies and Identity Protection. **Why:** Conditional Access authentication strengths require P1; risk-driven enforcement requires P2. **Verify:** Entra → **Overview**; or M365 admin center → **Billing** → **Licenses** (look for Entra ID P1/P2, included in M365 E3/E5 and Business Premium). **Implement:** Assign M365 E3/E5, Business Premium, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Appropriate Entra admin roles for the operator. **Why:** Editing authentication methods and Conditional Access requires elevated rights. **Verify:** Entra → **Roles and administrators**; confirm **Authentication Policy Administrator** (methods) and **Conditional Access Administrator** (policies). **Implement:** Assign **Authentication Policy Administrator** + **Conditional Access Administrator**; reserve **Global Administrator** for tenant-wide changes.

G4. Break-glass (emergency-access) accounts

Description: At least two cloud-only emergency-access accounts excluded from Conditional Access. **Why:** A misconfigured authentication-strength or MFA policy can lock out every admin; break-glass accounts preserve access. **Verify:** Entra → **Users**; two `*.onmicrosoft.com` accounts exist and are excluded from all CA policies. **Implement:** Create two cloud-only Global Administrator accounts with long passphrases, store credentials offline, exclude them from every CA policy, and monitor their sign-ins.

G5. Authentication methods policy access

Description: The tenant uses the **Authentication methods** policy (the modern, converged surface) to manage methods. **Why:** FIDO2, Windows Hello for Business, and certificate-based auth are enabled here, not in legacy per-method blades. **Verify:** Entra → **Protection** → **Authentication methods** → **Policies** opens. **Implement:** If still on the legacy MFA/SSPR method settings, migrate to the Authentication methods policy (Microsoft's guided migration toggle).

G6. Conditional Access baseline

Description: Conditional Access is available and at least a baseline MFA policy exists (or security defaults are understood). **Why:** Phishing-resistant enforcement is delivered through Conditional Access authentication strengths. **Verify:** Entra → **Protection** → **Conditional Access** → **Policies** lists policies; security defaults state is known. **Implement:** Disable security defaults only when replacing them with explicit CA policies; start in **Report-only** before enforcing.

G7. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS to Microsoft 365 / Entra sign-in and registration endpoints. **Why:** Method registration, sign-in, and policy evaluation depend on these endpoints. **Verify:** From a device, reach `https://login.microsoftonline.com` and `https://aka.ms/mysecurityinfo`. **Implement:** Allow Microsoft's published Microsoft 365 / Entra URL & IP ranges through proxy/firewall.

The deployment model (all solutions): Assess → Configure → Pilot → Validate → Expand.

GCC High Parity Notes — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys

This reference records what is **confirmed**, what **differs**, and what is **unconfirmed** for passwordless / phishing-resistant authentication on the **US Government (GCC High / DoD) cloud** versus Commercial. Every claim is cited to Microsoft documentation or explicitly flagged **"verify for GCC High"** where Microsoft has not confirmed sovereign parity. **Never assume Commercial parity** for preview features, Microsoft Authenticator passkey capabilities, or cross-cloud behavior. Sovereign availability changes — verify against current Microsoft US Gov documentation at deployment time.

1. Sovereign endpoints (confirmed)

Use the `*.us` plane for every portal, sign-in, and Graph call. The Commercial endpoints reject GCC High accounts.

Purpose	GCC High (US Gov L4)	DoD (US Gov L5)	Commercial
Microsoft Entra admin center	`https://entra.microsoft.us`	`https://entra.microsoft.us`	`https://entra.microsoft.com`
Azure portal	`https://portal.azure.us`	`https://portal.azure.us`	`https://portal.azure.com`
Microsoft 365 admin center	`https://portal.office365.us`	`https://portal.office365.us`	`https://admin.microsoft.com`
Sign-in / authentication	`https://login.microsoftonline.us`	`https://login.microsoftonline.us`	`https://login.microsoftonline.com`
Security-info registration	`https://aka.ms/mysecurityinfo` (resolves to the sovereign My Sign-Ins)	same	`https://aka.ms/mysecurityinfo`
Microsoft Graph	`https://graph.microsoft.us`	`https://dod-graph.microsoft.us`	`https://graph.microsoft.com`

Purpose	GCC High (US Gov L4)	DoD (US Gov L5)	Commercial
Graph PowerShell `-Environment`	`USGov`	`USGovDoD`	`Global`

Sources:

- Microsoft Learn — *Microsoft Graph national cloud deployments* (`https://learn.microsoft.com/en-us/graph/deployments`): Graph = `graph.microsoft.us` (GCC High) / `dod-graph.microsoft.us` (DoD); Azure portal `portal.azure.us`; Entra ID sign-in `login.microsoftonline.us`. Also: **Graph Explorer is "Not supported"** for the US Gov L4/L5 endpoints.
- Microsoft Learn — *Microsoft 365 U.S. Government GCC High endpoints* (`https://learn.microsoft.com/en-us/microsoft-365/enterprise/microsoft-365-u-s-government-gcc-high-endpoints`): sovereign admin portals (`portal.office365.us`, `portal.azure.us`).
- Microsoft Learn — *Connect-MgGraph* national-cloud `-Environment` values (`USGov` → `graph.microsoft.us`, `USGovDoD` → `dod-graph.microsoft.us`): `https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.authentication/connect-mggraph`.

2. Phishing-resistant methods — Generally Available in US Gov (confirmed)

Microsoft's *Entra feature availability in Azure for US Government* (page `ms.date` 2026-01-15) lists the following under **Authentication, single sign-on, and MFA** as available (■):

Capability	US Gov availability	Notes
Multifactor authentication (MFA)	■ Available	Baseline MFA.
Passwordless — **Windows Hello for Business, Microsoft Authenticator, FIDO2 security key integrations**	■ Available	The exact table wording groups all three passwordless methods under one ■ row.
Certificate-based authentication (CBA)	■ Available	The DoD-critical method for **CAC / PIV smart cards** — see §3.
Conditional Access	■ Available	Delivers **authentication strengths** (the enforcement layer).
Federated authentication (AD FS / other IdP)	■ Available	Relevant only if federating; direct CBA to Entra is preferred over AD FS.

Source: Microsoft Learn — *Microsoft Entra feature availability in Azure for US Government* (`https://learn.microsoft.com/en-us/entra/identity/authentication/feature-availability`), exact rows: "Passwordless (Windows Hello for Business, Microsoft Authenticator, FIDO2 security key integrations) ■"; "Certificate-based authentication ■"; "Conditional Access ■".

Implication: the core deployment in this solution — enable **FIDO2 security keys**, **Windows Hello for Business**, and/or **certificate-based authentication**; get users registered; create a **phishing-resistant authentication strength**; and require it via **Conditional Access** — is fully supported on GCC High. Build the whole program on these GA methods.

3. Certificate-based authentication (CBA) — the DoD / federal path (confirmed GA; details verify)

For **DoD (CAC)** and **federal civilian (PIV)** tenants, CBA is usually the primary phishing-resistant method because the smart-card credential already exists. CBA authenticates the **X.509 certificate directly to Microsoft Entra ID** (not through AD FS), which Microsoft and the U.S. GSA describe as a phishing-resistant sign-in that can be required with Conditional Access.

- CBA is listed ■ **Available** for US Gov (feature-availability table, §2).
- Deployment requires: uploading the issuing/root **CA chain** to the Entra **certificate authorities** trust store, configuring **username binding** (map a certificate field — e.g. `PrincipalName` / `RFC822Name`, or the `certificateUserIds` attribute — to the user), and setting **authentication-binding** rules that decide which certificate policy OIDs count as single-factor vs multifactor (MFA).
- To count as **phishing-resistant MFA**, the certificate must be issued to a **hardware smart card** (CAC/PIV) and mapped via a **high-affinity binding**; Microsoft's phishing-resistant authentication-strength guidance covers which CBA bindings qualify. **Verify the current binding requirements for GCC High/DoD** at deployment time.

Sources:

- Microsoft Learn — *Microsoft Entra feature availability in Azure for US Government* (CBA ■).
- U.S. GSA IDManagement — *Certificate-Based Authentication on Microsoft Entra ID* (`https://www.idmanagement.gov/implement/cba-azure/`): direct X.509 auth to Entra ID is a phishing-resistant, Conditional-Access-verifiable login for PIV/CAC.
- Microsoft Learn — *How to configure Microsoft Entra certificate-based authentication* and *Certificate-based authentication technical deep dive* (bindings, `certificateUserIds`). **Verify for GCC High** — confirm the CBA configuration steps and any DoD-specific binding notes against the current sovereign docs.

4. Known differences and limitations vs Commercial (confirmed)

Area	Commercial	US Gov (GCC High / DoD)	Source
Graph Explorer (browser tool)	Supported	**Not supported** for `graph.microsoft.us` / `dod-graph.microsoft.us` — use PowerShell `-Environment USGov`	Graph national cloud deployments
Delegated user-management portal (**My Staff**)	Available	**Not available (■)** — no delegated helpdesk portal for frontline TAP/registration assistance	Entra feature availability for US Government

Area	Commercial	US Gov (GCC High / DoD)	Source
Microsoft Entra threat intelligence (ID Protection detection)	Available	**Not available (■)** — noted because risk-based Conditional Access on top of the phishing-resistant grant has one fewer detection source	Entra feature availability for US Government
Shared device sign-out / **Enterprise state roaming** (Windows 10)	Available	**Not available** for Windows 10 devices	Entra feature availability for US Government

Note: most **ID Protection risk detections** (leaked credentials, anonymous IP, atypical/impossible travel, password spray, etc.) **are ■ available** in US Gov — only *Microsoft Entra threat intelligence* is ■. So risk-based enforcement is still possible; just do not design around the threat-intelligence signal.

5. Verify for GCC High (unconfirmed sovereign parity — do not assume Commercial parity)

The following are **Preview**, **Microsoft-Authenticator-dependent**, or **cross-cloud** in Commercial and are **not confirmed** for GCC High at authoring time. Treat each as "verify for GCC High" and default to the GA path (hardware FIDO2 keys, Windows Hello for Business, or CBA/smart card):

• **Passkeys in Microsoft Authenticator** (device-bound passkeys in the Authenticator app), **cross-device passkey sign-in via QR code**, and **synced passkeys** (Apple iCloud Keychain / Google Password Manager). Microsoft's passkey concept page does not confirm sovereign-cloud availability, and Microsoft Authenticator features frequently lag in the US Gov clouds. **Verify for GCC High.** The GA, sovereign-safe choice is a **hardware FIDO2 security key** or **CBA smart card**, not a synced/phone passkey. Source: Microsoft Learn — *Passkeys (FIDO2) authentication method in Microsoft Entra ID* (`https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-passkeys-fido2`).

• **Temporary Access Pass (TAP)** as the bootstrap credential for registering a first passwordless method. TAP is not called out separately in the US Gov feature-availability table; Microsoft documents it under passwordless onboarding for Commercial. **Verify for GCC High** before designing frontline onboarding around TAP; have a fallback (in-person key enrollment or CBA issuance) if TAP is unavailable. Source: Microsoft Learn — *Configure a Temporary Access Pass* (`https://learn.microsoft.com/en-us/entra/identity/authentication/howto-authentication-temporary-access-pass`).

• **Registration campaign** to nudge users to add a passwordless method at sign-in. The converged Authentication methods policy is available in US Gov, but confirm the **registration campaign** sub-feature (and which methods it can nudge) is present in your sovereign tenant. **Verify for GCC High**; if absent, drive registration by direct communication + supervised enrollment.

• **FIDO2 provisioning / Microsoft-managed AAGUID conveniences and passkey profiles** that appear in Commercial previews — **verify for GCC High.** AAGUID **restriction** (allow-listing specific certified key models) in the FIDO2 method settings is part of the GA FIDO2 configuration and is expected; confirm the exact UI in the sovereign portal.

• **Hybrid FIDO2 (on-prem SSO to AD DS with a security key)** — supported in Commercial for Entra hybrid-joined Windows; confirm the on-prem components (Kerberos-trust / cloud Kerberos) and version prerequisites for your GCC High + on-prem AD environment. **Verify for GCC High.**

*General rule: features marked **Preview** in Microsoft's Commercial docs, and anything that depends on the **Microsoft Authenticator app** or **cross-cloud** behavior, should be assumed **later or absent** in the sovereign clouds until Microsoft's US Gov documentation confirms them. When in doubt, flag "verify for GCC High" and deploy the GA path: **hardware FIDO2 key, Windows Hello for Business, or CBA smart card**, enforced with a Conditional Access authentication strength.*

6. Sources

• Microsoft Learn — *Microsoft Entra feature availability in Azure for US Government*: `https://learn.microsoft.com/en-us/entra/identity/authentication/feature-availability`

• Microsoft Learn — *Microsoft Graph national cloud deployments*: `https://learn.microsoft.com/en-us/graph/deployments`

• Microsoft Learn — *Connect-MgGraph (Microsoft.Graph.Authentication)* national-cloud `-Environment` values: `https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.authentication/connect-mggraph`

• Microsoft Learn — *Microsoft 365 U.S. Government GCC High endpoints*: `https://learn.microsoft.com/en-us/microsoft-365/enterprise/microsoft-365-u-s-government-gcc-high-endpoints`

• Microsoft Learn — *Passkeys (FIDO2) authentication method in Microsoft Entra ID*: `https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-passkeys-fido2`

• Microsoft Learn — *How to enable passkeys (FIDO2) in Microsoft Entra ID*: `https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-authentication-passkeys-fido2`

• Microsoft Learn — *Configure a Temporary Access Pass*: `https://learn.microsoft.com/en-us/entra/identity/authentication/howto-authentication-temporary-access-pass`

• U.S. GSA IDManagement — *Certificate-Based Authentication on Microsoft Entra ID*: `https://www.idmanagement.gov/implement/cba-azure/`

• Microsoft Learn — *Get started with phishing-resistant MFA deployment in Microsoft Entra ID* (phishing-resistant authentication-strength guidance).

3. Implementation Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Follow these steps **in order**, in the **sovereign** Microsoft Entra admin center (`https://entra.microsoft.us`). This is the Government (GCC High) edition — every portal is a `*.us` URL and every script uses `-Environment USGov` (or `USGovDoD` for DoD).

> ***Model:*** *Enable the methods, get a* ***pilot*** *registered, create a phishing-resistant authentication strength, require it via Conditional Access on the pilot, validate, then expand to all staff. Registration always leads enforcement so no one is locked out.* ***Naming convention*** *— every object uses* `<Purpose> – <Scope> – <Stage>`*. Create these and reuse the names verbatim: - Groups:* `Phishing-Resistant – Pilot – Users`*,* `Phishing-Resistant – All Staff – Users` *- Authentication strength:* `Phishing-Resistant – All Staff – Standard` *- Conditional Access (pilot):* `Phishing-Resistant – Pilot – Enforce` *- Conditional Access (broad):* `Phishing-Resistant – All Staff – Enforce` ***GCC High caveat (read first):*** *the core methods (FIDO2, Windows Hello for Business, certificate-based auth) and Conditional Access authentication strengths are* ***GA in US Gov****.* ***Authenticator passkeys, cross-device/QR passkeys, synced passkeys, Temporary Access Pass, and the registration campaign are "verify for GCC High"*** *— confirm each is present in *your* sovereign tenant before relying on it (see* `gcc-high-parity-notes.md`*). Where a feature is absent, use the stated fallback.*

Step 1 — Create the groups

1. Entra (`entra.microsoft.us`) → **Groups** → **New group** → **Security** → name `Phishing-Resistant – Pilot – Users` (a few representative users + admins). **Create**.
2. Create `Phishing-Resistant – All Staff – Users` (everyone in scope). **Create**.

(Or build both with `FIDO2G-Set-ScopeTargeting.ps1` — default `-WhatIf`.)

Step 2 — Enable FIDO2 security keys

1. Entra → **Protection** → **Authentication methods** → **Policies** → **FIDO2 security key** (or *Passkey (FIDO2)*).
2. Set **Enable** to **Yes**; **Target** to `Phishing-Resistant – Pilot – Users` (expand later).
3. Under **Configure**: leave **Allow self-service set up** = Yes; optionally **restrict by AAGUID** to allow-list your FIPS-validated key models. **Save**.

> ***GCC High:*** *hardware FIDO2 keys are the GA, sovereign-safe choice. Do* ***not*** *design around* ***synced/phone passkeys or Authenticator passkeys*** *— those are *verify for GCC High*.*

Step 3 — Enable Windows Hello for Business

1. Entra → **Protection** → **Authentication methods** → **Policies** → **Windows Hello for Business** (or manage via Intune at `https://endpoint.microsoft.us`).
2. **Enable** and **Target** `Phishing-Resistant – Pilot – Users`. **Save**.

Step 4 — Enable certificate-based authentication (CAC / PIV) — primary for DoD/federal

1. Entra → **Protection** → **Show more** → **Certificate-based authentication** — confirm the **CA chain** is uploaded to the certificate-authorities store and **username binding** is set (e.g. `PrincipalName` / `RFC822Name`, or `certificateUserIds`).

2. Set the **authentication-binding** so a hardware-smart-card (CAC/PIV) certificate policy counts as **MFA** (single- vs multi-factor by certificate policy OID).

3. Then **Protection** → **Authentication methods** → **Policies** → **Certificate-based authentication** → **Enable**, **Target** the pilot. **Save**.

GCC High: *CBA is ■ **GA** in US Gov and is usually the *primary* phishing-resistant method where CAC/PIV already exist.* ***Verify the current binding requirements for GCC High/DoD*** *before you rely on the MFA/high-affinity binding (`gcc-high-parity-notes.md` §3).*

Step 5 — Decide the onboarding bootstrap (verify TAP for GCC High)

1. Entra → **Protection** → **Authentication methods** → **Policies** → **Temporary Access Pass**. If **present**, set **Enable = Yes**, **Target** `Phishing-Resistant – Pilot – Users`; use a short lifetime. **Save**.

2. If TAP is **not available** in your sovereign tenant, use **in-person supervised enrollment** (hand out and register the FIDO2 key with the user present) or **CAC/PIV issuance** as the bootstrap.

GCC High: *TAP is *verify for GCC High* — do not assume it exists. Have the supervised-enrollment fallback ready.*

Step 6 — Register the pilot

1. If the **Registration campaign** is present (Entra → **Protection** → **Authentication methods** → **Registration campaign**), set **State = Enabled**, **Include** `Phishing-Resistant – Pilot – Users`, choose the passwordless methods to nudge. **Save**.

2. Direct pilot users to the sovereign security-info portal `https://aka.ms/mysecurityinfo` to register a FIDO2 key or enroll Windows Hello now (or issue/verify their CAC/PIV).

GCC High: *the registration campaign is *verify for GCC High*. If absent, drive registration by direct communication plus supervised enrollment — do not let this block the rollout.*

Step 7 — Create the phishing-resistant authentication strength

1. Entra → **Protection** → **Authentication methods** → **Authentication strengths**.

2. Use the built-in **Phishing-resistant MFA** strength, or **New authentication strength** named `Phishing-Resistant – All Staff – Standard` and select **FIDO2**, **Windows Hello for Business**, and (where used) **certificate-based auth**. **Save**.

Step 8 — Enforce on the pilot via Conditional Access

1. Entra → **Protection** → **Conditional Access** → **Create new policy**. **Name:** `Phishing-Resistant – Pilot – Enforce`.

2. **Users:** include `Phishing-Resistant – Pilot – Users`; **exclude** the two break-glass accounts.

3. **Target resources:** All cloud apps (or a pilot app first).

4. **Grant: Require authentication strength** → select `Phishing-Resistant – All Staff – Standard` (or built-in Phishing-resistant MFA).

5. **Enable policy: Report-only** first. **Create**.

Step 9 — Validate the pilot

1. Have a pilot user sign in; confirm a phishing-resistant credential is requested (or, in Report-only, that it *would* be required).

2. Run `FIDO2G-Validation.ps1` for a pilot user → confirms a phishing-resistant method is registered as default (US Gov Graph).

3. Run `FIDO2G-Report.ps1` → confirms pilot coverage. Complete the **Testing Guide**. Then switch the pilot policy from **Report-only** to **On**.

Step 10 — Expand to all staff

1. Confirm registration coverage with `FIDO2G-Report.ps1` for `Phishing-Resistant – All Staff – Users` (do not enforce ahead of registration).

2. Widen the method-policy **Target** (and the registration campaign, if used) to `Phishing-Resistant – All Staff – Users`.

3. Create `Phishing-Resistant – All Staff – Enforce` (same grant), scope to all staff, exclude break-glass, run **Report-only**, then turn **On** once coverage is high. Use `FIDO2G-Remediation.ps1` (default `-WhatIf`) to help laggards.

Order of operations

`Groups → enable FIDO2 → enable Windows Hello → certificate-based auth (CAC/PIV) → bootstrap (TAP/verify or supervised) → register pilot → authentication strength → CA enforce on pilot → validate → expand to all staff`

> *Every step above runs on the **sovereign** `*.us` plane. If a portal shows `.com`, you are in the wrong cloud — a GCC High account will not authenticate there.*

5. Testing Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Run after the pilot is configured (Implementation Step 8) and again before expanding to all staff. This is the Government (GCC High) edition — every portal is a `*.us` URL and every script runs with `-Environment USGov` (or `USGovDoD` for DoD).

Test 0 — Sovereign cloud confirmed

Do: Sign in at `https://entra.microsoft.us`; run `FIDO2G-Discovery.ps1` (connects `-Environment USGov`). **Expected:** Portal is a `*.us` URL and resolves your GCC High tenant; the script connects to `graph.microsoft.us` (or `dod-graph.microsoft.us`) without an endpoint error. A `.com`

portal or a Commercial-Graph connection is a **fail** — you are in the wrong cloud.

Test 1 — Methods enabled

Do: Entra → **Protection** → **Authentication methods** → **Policies**; check FIDO2, Windows Hello for Business, and (for DoD/federal) certificate-based auth; or run `FIDO2G-Discovery.ps1`. **Expected:** The intended methods are **Enabled** and **Targeted** at the pilot group.

Test 2 — User can register a phishing-resistant credential

Do: A pilot user goes to `https://aka.ms/mysecurityinfo` → **Add sign-in method** → **Security key** and registers a FIDO2 key (or enrolls Windows Hello, or verifies their CAC/PIV sign-in). **Expected:** The credential registers without error and appears in the user's security info.

Test 3 — Passwordless sign-in works

Do: The pilot user signs out and signs in using the FIDO2 key, Windows Hello, or CAC/PIV smart card. **Expected:** Sign-in succeeds **without a password**.

Test 4 — Registration coverage

Do: Run `FIDO2G-Validation.ps1 -UserId <pilot user>` and `FIDO2G-Report.ps1`. **Expected:** The pilot user has a phishing-resistant method registered; the report shows pilot coverage rising (data pulled from US Gov Graph).

Test 5 — Authentication strength exists

Do: Entra → **Protection** → **Authentication methods** → **Authentication strengths**. **Expected:** `Phishing-Resistant – All Staff – Standard` (or the built-in Phishing-resistant MFA) lists FIDO2 / Windows Hello / (certificate-based).

Test 6 — Conditional Access enforces the strength

Do: With `Phishing-Resistant – Pilot – Enforce` set to **On**, have a pilot user attempt password + SMS/push, then the phishing-resistant credential. **Expected:** Weak methods are **blocked**; the phishing-resistant credential **succeeds**.

Test 7 — Break-glass unaffected

Do: Confirm a break-glass account is excluded and can still sign in. **Expected:** Break-glass accounts are not subject to the strength policy.

Test 8 — Certificate-based auth counts as MFA (if used)

Do: A CAC/PIV user signs in with the smart card against a resource protected by the phishing-resistant strength. **Expected:** The smart-card sign-in satisfies the strength (the authentication-binding maps the hardware certificate policy to MFA). If it is treated as single-factor, revisit the CBA binding (see `gcc-high-parity-notes.md` §3 — **verify for GCC High**).

Pass/fail gate

Gate	Requirement
Sovereign	Test 0 passes — administering and scripting on the `*.us` plane
Pilot pass	Tests 1–6 (and Test 8 where CBA is used) pass for the pilot; break-glass excluded (Test 7)
Broad pass	Coverage high for all staff (Test 4) before `Phishing-Resistant – All Staff – Enforce` is turned **On**

6. Troubleshooting Guide — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Use `FIDO2G-Discovery.ps1` for tenant method state, `FIDO2G-Validation.ps1` for a user's registered methods, `FIDO2G-Report.ps1` for coverage, and `FIDO2G-Remediation.ps1` (default `-WhatIf`) for laggards. All scripts run against **US Gov Graph** (`-Environment USGov`, or `USGovDoD` for DoD).

A. Wrong cloud / sovereign-endpoint problems (GCC High-specific — check first)

Symptom	Cause	Remediation
Portal shows `.com` / your account isn't recognized	Signed in to a Commercial portal	Use the sovereign portals: `entra.microsoft.us`, `portal.azure.us`, `portal.office365.us`
Script auth fails or returns the wrong tenant / "AADSTS" endpoint errors	`Connect-MgGraph` defaulted to Commercial Graph	Pass `-Environment USGov` (or `USGovDoD`); all package scripts default to `USGov`
Graph Explorer won't work against your tenant	Graph Explorer is **not supported** for `graph.microsoft.us` / `dod-graph.microsoft.us`	Use the PowerShell scripts in this package instead
A documented feature/menu is missing	Commercial-only, Preview, or Authenticator/cross-cloud feature not in US Gov	Check `gcc-high-parity-notes.md`; use the GA fallback (hardware FIDO2 / Windows Hello / CBA)

B. Users locked out after enforcement

Symptom	Cause	Remediation
Users can't sign in after the strength policy turns on	Enforced before users registered a phishing-resistant method	Set the CA policy to **Report-only**, drive registration, confirm coverage with `FIDO2G-Report.ps1`, then re-enable
Admins locked out	Break-glass accounts not excluded	Sign in with break-glass; exclude them from every CA policy (global G4). On GCC High, recovery is slower — keep break-glass current

C. FIDO2 key won't register

Symptom	Cause	Remediation
"Security key" option missing at `aka.ms/mysecurityinfo`	FIDO2 not enabled or user not targeted	Enable FIDO2 and target the user's group; run `FIDO2G-Discovery.ps1`
Key rejected during registration	Key model blocked by AAGUID restriction, or unsupported browser/OS	Allow the model's AAGUID (or remove the restriction); use a supported browser/OS. Prefer FIPS-validated keys
You expected a phone/synced passkey option and it's absent	Authenticator/synced passkeys are **verify for GCC High** — likely not available	Use a **hardware FIDO2 key** or **CBA smart card** (the GA path); do not depend on synced passkeys

D. Onboarding bootstrap missing (TAP)

• If **Temporary Access Pass** is not present in the sovereign Authentication methods policy, that is expected — **TAP is verify for GCC High**. Use **supervised in-person enrollment** (register the FIDO2 key with the user present) or **CAC/PIV issuance** as the bootstrap instead of blocking on TAP.

E. Windows Hello for Business not provisioning

• Confirm the device is Entra-joined/registered and has a TPM; confirm Windows Hello for Business is enabled (Authentication methods policy or Intune at `endpoint.microsoft.us`) and the user is targeted.

F. Conditional Access not requiring the strength

Symptom	Cause	Remediation
Weak methods still work	Policy in Report-only, or wrong grant	Confirm the policy is **On** and the grant is **Require authentication strength** with the right strength selected

Symptom	Cause	Remediation
Some apps bypass it	Legacy/non-modern-auth apps/protocols	Inventory and remediate or scope them; don't leave permanent broad exclusions

G. Certificate-based authentication (CAC/PIV) failing

Symptom	Cause	Remediation
Smart-card sign-in fails	CA chain not uploaded, invalid trust/issuer, or revocation check failing	Confirm the issuing/root CA chain is in the Entra certificate-authorities store; check certificate validity/CRL/OCSP
User can't be matched to the certificate	Username binding not configured	Configure username binding (`PrincipalName` / `RFC822Name`, or `certificateUserIds`)
CBA works but only counts as single-factor (strength not satisfied)	Authentication-binding maps the certificate policy to single-factor	Set the authentication-binding so the hardware-smart-card certificate policy counts as **MFA**. **Verify the current GCC High/DoD binding requirements** (`gcc-high-parity-notes.md` §3)

H. Diagnostics quick reference (Microsoft Graph PowerShell — US Gov)

```
Connect-MgGraph -Environment USGov -Scopes 'Policy.Read.All','UserAuthenticationMethod.Read.All','AuditLog
# (DoD tenants: -Environment USGovDoD)

# Tenant method policy (FIDO2, Windows Hello, CBA)
Invoke-MgGraphRequest GET '/v1.0/policies/authenticationMethodsPolicy'
# A user's registered methods
Invoke-MgGraphRequest GET "/v1.0/users/<upn>/authentication/methods"
# Registration details (coverage)
Invoke-MgGraphRequest GET '/v1.0/reports/authenticationMethods/userRegistrationDetails'
```

> *Placeholders use a plain form (`<upn>`) in this diagnostic block only for clarity; the packaged scripts take real parameters (e.g. `-UserId`) and never require you to edit angle-bracket text.*

I. When to escalate

If methods are enabled and targeted on the **sovereign** tenant, the user has registered a phishing-resistant method, the CA policy grant is correct, and sign-in still fails, collect the Entra **Sign-in logs** entry (the failed CA policy + authentication-strength detail) at `entra.microsoft.us` and open a Microsoft support case **for the US Government cloud**. Note the tenant is GCC High (or DoD) in the case so it routes to the sovereign support queue.

7. Best Practices — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Field-proven recommendations for deploying phishing-resistant, passwordless authentication on a US sovereign (GCC High / DoD) tenant.

Sovereign-cloud discipline

- **Administer only on the `*.us` plane.** Bookmark `entra.microsoft.us`, `portal.azure.us`, `portal.office365.us`, and `endpoint.microsoft.us`. A GCC High account will not authenticate against the Commercial `*.com` portals.
- **Always pass `-Environment USGov`** (or `USGovDoD`) in every Graph script. Without it the SDK silently targets `graph.microsoft.com` and fails against your tenant. All five scripts in this package default to `USGov`.
- **Use PowerShell, not Graph Explorer.** Graph Explorer is not supported for `graph.microsoft.us` / `dod-graph.microsoft.us`. This package's read-only scripts are the sovereign-safe equivalent.
- **Never assume Commercial parity.** Anything Authenticator-based, cross-cloud, or marked Preview in Commercial is "verify for GCC High." Default to the GA path.

Choose the right method for government

- **Lead with CAC/PIV (certificate-based auth) where cards already exist.** For DoD (CAC) and federal-civilian (PIV) tenants, CBA is usually the primary phishing-resistant method — the credential is already on the badge, and it authenticates direct to Entra ID (no AD FS). It is **GA in US Gov**.
- **Use hardware FIDO2 keys for roaming users, admins, shared workstations, and frontline** who have no assigned PC or smart card. Prefer **FIPS 140-validated** keys.
- **Use Windows Hello for Business for assigned, single-user PCs.**
- **Do not build on synced/phone/Authenticator passkeys** for the sovereign rollout — they are *verify for GCC High*. If a pilot confirms they exist, treat them as a convenience tier, not the compliance path.

Registration always leads enforcement

- **Never require a phishing-resistant strength before users are registered** — it locks them out. Confirm coverage with `FIDO2G-Report.ps1` first.
- **Decide the onboarding bootstrap up front.** TAP is *verify for GCC High*; have **supervised in-person enrollment** (or CAC/PIV issuance) as the guaranteed fallback so a missing TAP never blocks the program.
- **Pilot with real roles** — include a roaming admin, a frontline/shared-workstation user, and a CAC/PIV holder so every method path is exercised before broad rollout.

Conditional Access safety

- **Start every enforcement policy in Report-only**, review sign-in logs, then flip to On.

• **Exclude two break-glass accounts from every policy** and monitor their sign-ins. On GCC High, support-assisted recovery is slower — break-glass matters more.

• **Inventory legacy apps/protocols** that don't honor modern auth before tenant-wide enforcement; scope exclusions deliberately.

• **Reuse one named authentication strength** (`Phishing-Resistant – All Staff – Standard`) across policies rather than creating ad-hoc strengths.

Key/credential lifecycle

• **Restrict FIDO2 by AAGUID** to allow-list only approved, certified key models.

• **Track key inventory** (serial ↔ user) for CAC/PIV-adjacent accountability; plan for lost-key recovery before rollout, not after.

• **Set a reissuance/recertification cadence** consistent with your NIST 800-171 / CMMC controls.

Naming, reuse, and auditability

• Use the `<Purpose> – <Scope> – <Stage>` convention verbatim (`Phishing-Resistant – Pilot – Users`, … `– All Staff – Enforce`) so every object is self-documenting for auditors.

• Keep the pilot and rollout groups authoritative (build/populate with `FIDO2G-Set-ScopeTargeting.ps1`) rather than hand-editing membership.

• Retain `FIDO2G-Report.ps1` output as coverage evidence for compliance reviews (phishing-resistant-MFA posture over time).

Compliance framing

• Map the deployment to **EO 14028 / OMB M-22-09** phishing-resistant-MFA direction and **CMMC / NIST SP 800-171** authentication and access-control objectives. The named strength + Conditional Access policy + coverage report together form the provable control.

8. Deliverables Summary — Passwordless & Phishing-Resistant MFA with FIDO2 Security Keys — Government (GCC High)

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box (GCC High edition)
1. Solution Overview	What passwordless/phishing-resistant auth is; FIDO2 vs. Windows Hello vs. certificate-based (CAC/PIV); authentication strengths; **Commercial vs GCC High — what's different**; benefits; limitations

Document	Purpose
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing, on the `*.us` plane
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered **sovereign** Entra steps with GCC-High caveats inline
5. Testing Guide	Validation procedures with pass/fail gates (incl. sovereign + CBA-as-MFA tests)
6. Troubleshooting Guide	Field issues and remediation, GCC-High-specific gotchas
7. Best Practices	Field-proven recommendations for a US Gov tenant
GCC High Parity Notes	Cited confirmed/differs/verify reference for US Gov vs Commercial

PowerShell scripts (US Gov Graph — `-Environment USGov`)

Script	What it does
`FIDO2G-Discovery.ps1`	Reports tenant authentication-method policy state (FIDO2 / Windows Hello / certificate-based enabled + targeting) — read-only
`FIDO2G-Validation.ps1`	Confirms a user has a phishing-resistant method registered (and as default) — read-only
`FIDO2G-Report.ps1`	Tenant credential-method coverage report from registration details (US Gov Graph) — read-only
`FIDO2G-Remediation.ps1`	Safe remediation for weak-method users (default `-WhatIf`); flags users lacking a phishing-resistant method
`FIDO2G-Set-ScopeTargeting.ps1`	Builds/populates the pilot and rollout Entra groups for staged targeting (default `-WhatIf`)

All scripts connect to Microsoft Graph **US Gov** endpoints (`-Environment USGov`, or `USGovDoD` for DoD). Discovery, Validation, and Report are strictly read-only; Remediation and Set-ScopeTargeting default to `-WhatIf` and make no change until you pass `-Execute`.

What the buyer receives

- This implementation guide as a **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

Outcome

Users signing in passwordless with phishing-resistant credentials — FIDO2 keys, Windows Hello for Business, and CAC/PIV smart cards — and weak methods blocked by a Conditional Access authentication strength, all configured on the **US sovereign (`*.us`) cloud** and proven on a pilot before fleet rollout.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

FIDO2G-Discovery.ps1

Purpose: Reports the current authentication-methods posture in a US Government (GCC High/DoD) tenant: whether FIDO2 security keys, Windows Hello for Business, certificate-based authentication, and Temporary Access Pass are enabled and who they target, plus which authentication strengths exist. Read-only. Use -Environment USGovDoD on the DoD cloud. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\FIDO2G-Discovery.ps1 Connects to US Gov Graph (-Environment USGov). Read-only scopes: Policy.Read.All, Policy.Read.ConditionalAccess. EXPECTED RESULTS Per-method enabled state and target scope, TAP presence (verify for GCC High), and a list of authentication strengths. Pass = posture printed against graph.microsoft.us; fail = a connection/redirect error means -Environment was omitted (SDK hit the Commercial endpoint). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'Policy.Read.All','Policy.Read.ConditionalAccess' -NoWelcome

How to run: powershell -ExecutionPolicy Bypass -File .\FIDO2G-Discovery.ps1 Connects to US Gov Graph (-Environment USGov). Read-only scopes: Policy.Read.All, Policy.Read.ConditionalAccess. EXPECTED RESULTS Per-method enabled state and target scope, TAP presence (verify for GCC High), and a list of authentication strengths. Pass = posture printed against graph.microsoft.us; fail = a connection/redirect error means -Environment was omitted (SDK hit the Commercial endpoint). .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'Policy.Read.All','Policy.Read.ConditionalAccess' -NoWelcome

FIDO2G-Remediation.ps1

Purpose: Finds users in a US Government (GCC High/DoD) tenant who lack a phishing-resistant, passwordless method and, optionally, adds them to a remediation/registration group so a registration campaign or supervised-enrollment drive can target them. Makes NO change in the default preview (-WhatIf) mode; add -WhatIf:$false to apply. It never disables a user's existing methods and never enforces a policy. Use -Environment USGovDoD on the DoD cloud. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\FIDO2G-Remediation.ps1 -RemediationGroupName "Phishing-Resistant - Needs Registration - Remediation" Apply: add -WhatIf:$false to the same command after reviewing the preview. Connects to US Gov Graph (-Environment USGov). Scopes: AuditLog.Read.All, UserAuthenticationMethod.Read.All, Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS A list of users lacking a phishing-resistant method; in preview it prints what WOULD be added to the remediation group; with -WhatIf:$false it adds them and prints the group object ID. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. >

[CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$RemediationGroupName = 'Phishing-Resistant - Needs Registration - Remediation', [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'AuditLog.Read.All','UserAuthenticationMethod.Read.All','Group.ReadWrite.All','User.Read.All' -NoWelcome

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\FIDO2G-Remediation.ps1 -RemediationGroupName "Phishing-Resistant - Needs Registration - Remediation" Apply: add -WhatIf:$false to the same command after reviewing the preview. Connects to US Gov Graph (-Environment USGov). Scopes: AuditLog.Read.All, UserAuthenticationMethod.Read.All, Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS A list of users lacking a phishing-resistant method; in preview it prints what WOULD be added to the remediation group; with -WhatIf:$false it adds them and prints the group object ID. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$RemediationGroupName = 'Phishing-Resistant - Needs Registration - Remediation', [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'AuditLog.Read.All','UserAuthenticationMethod.Read.All','Group.ReadWrite.All','User.Read.All' -NoWelcome

FIDO2G-Report.ps1

Purpose: Produces a tenant-wide credential-method coverage report for a US Government (GCC High/DoD) tenant from Microsoft Graph authentication-method registration details: how many users are capable of passwordless / phishing-resistant sign-in, and lists users who are NOT yet ready. Use this to confirm coverage before requiring a phishing-resistant strength. Read-only, and can write a CSV. Use -Environment USGovDoD on the DoD cloud. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\FIDO2G-Report.ps1 -CsvPath .\fido2g-coverage.csv Connects to US Gov Graph (-Environment USGov). Read-only scopes: AuditLog.Read.All, UserAuthenticationMethod.Read.All. EXPECTED RESULTS Counts and percentages for passwordless-capable and MFA-registered users, and a list (and optional CSV) of users lacking a phishing-resistant method. Pass = report renders against graph.microsoft.us; fail = a connection/redirect error means -Environment was omitted. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([string]$CsvPath, [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'AuditLog.Read.All','UserAuthenticationMethod.Read.All' -NoWelcome

How to run: powershell -ExecutionPolicy Bypass -File .\FIDO2G-Report.ps1 -CsvPath .\fido2g-coverage.csv Connects to US Gov Graph (-Environment USGov). Read-only scopes: AuditLog.Read.All, UserAuthenticationMethod.Read.All. EXPECTED RESULTS Counts and percentages for passwordless-capable and MFA-registered users, and a list (and optional CSV) of users lacking a phishing-resistant method. Pass = report renders against graph.microsoft.us; fail = a connection/redirect

error means -Environment was omitted. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([string]$CsvPath, [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'AuditLog.Read.All','UserAuthenticationMethod.Read.All' -NoWelcome

FIDO2G-Set-ScopeTargeting.ps1

Purpose: Creates (idempotently) the security groups the phishing-resistant rollout targets in a US Government (GCC High/DoD) tenant: a pilot group and an all-staff group used by the Authentication methods policy targeting, the registration drive, and Conditional Access enforcement. Optionally seeds members by UPN. Consistent group names make method targeting, registration, and CA policies repeatable. Runs in -WhatIf (preview) mode by default; add -WhatIf:$false to create/modify. Use -Environment USGovDoD on the DoD cloud. HOW TO RUN Preview (default): powershell -ExecutionPolicy Bypass -File .\FIDO2G-Set-ScopeTargeting.ps1 -PilotUpns "alice@your-tenant.onmicrosoft.us","bob@your-tenant.onmicrosoft.us" Apply: add -WhatIf:$false to the same command after reviewing the preview. Connects to US Gov Graph (-Environment USGov). Scopes: Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS The pilot and all-staff groups exist (created if missing) with the requested members; their object IDs are printed for use in the Authentication methods policy target, the registration drive, and the Conditional Access authentication-strength policies. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$PilotGroupName = 'Phishing-Resistant - Pilot - Users', [string]$AllStaffGroupName = 'Phishing-Resistant - All Staff - Users', [string[]]$PilotUpns = @(), [string[]]$AllStaffUpns = @(), [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'Group.ReadWrite.All','User.Read.All' -NoWelcome

How to run: Preview (default): powershell -ExecutionPolicy Bypass -File .\FIDO2G-Set-ScopeTargeting.ps1 -PilotUpns "alice@your-tenant.onmicrosoft.us","bob@your-tenant.onmicrosoft.us" Apply: add -WhatIf:$false to the same command after reviewing the preview. Connects to US Gov Graph (-Environment USGov). Scopes: Group.ReadWrite.All, User.Read.All. EXPECTED RESULTS The pilot and all-staff groups exist (created if missing) with the requested members; their object IDs are printed for use in the Authentication methods policy target, the registration drive, and the Conditional Access authentication-strength policies. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([string]$PilotGroupName = 'Phishing-Resistant - Pilot - Users', [string]$AllStaffGroupName = 'Phishing-Resistant - All Staff - Users', [string[]]$PilotUpns = @(), [string[]]$AllStaffUpns = @(), [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'Group.ReadWrite.All','User.Read.All' -NoWelcome

FIDO2G-Validation.ps1

Purpose: For a given user in a US Government (GCC High/DoD) tenant, lists their registered authentication methods and reports whether a phishing-resistant, passwordless method (FIDO2 security key, Windows Hello for Business, or certificate-based/CAC-PIV) is registered — and whether the system-preferred/default sign-in method is phishing-resistant. Read-only. Use -Environment USGovDoD on the DoD cloud. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\FIDO2G-Validation.ps1 -UserId user@your-tenant.onmicrosoft.us Connects to US Gov Graph (-Environment USGov). Read-only scopes: UserAuthenticationMethod.Read.All, User.Read.All. EXPECTED RESULTS PASS if the user has at least one phishing-resistant method registered; the methods and the default method are printed. FAIL (yellow) if only weak methods (password, SMS, voice) exist — the user is not yet ready for phishing-resistant enforcement. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$UserId, [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'UserAuthenticationMethod.Read.All','User.Read.All' -NoWelcome

How to run: powershell -ExecutionPolicy Bypass -File .\FIDO2G-Validation.ps1 -UserId user@your-tenant.onmicrosoft.us Connects to US Gov Graph (-Environment USGov). Read-only scopes: UserAuthenticationMethod.Read.All, User.Read.All. EXPECTED RESULTS PASS if the user has at least one phishing-resistant method registered; the methods and the default method are printed. FAIL (yellow) if only weak methods (password, SMS, voice) exist — the user is not yet ready for phishing-resistant enforcement. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph US Gov endpoints. > [CmdletBinding()] param([Parameter(Mandatory=$true)][string]$UserId, [ValidateSet('USGov','USGovDoD')][string]$Environment = 'USGov') if (-not (Get-Module -ListAvailable -Name Microsoft.Graph.Authentication)) { Install-Module Microsoft.Graph -Scope CurrentUser -Force -AllowClobber } Import-Module Microsoft.Graph.Authentication -ErrorAction Stop Connect-MgGraph -Environment $Environment -Scopes 'UserAuthenticationMethod.Read.All','User.Read.All' -NoWelcome